

AlDeci One-Pager

DevOps.ai

January 2025

Contents

1 AlDeci Product One-Pager	1
1.1 Automate Trust. Prove Security.	1
1.2 The Problem	1
1.3 The AlDeci Solution	2
1.4 How AlDeci Works: 6-Step Decision Flow	2
1.5 MITRE ATT&CK: Dual Role	3
1.6 Proven Outcomes	3
1.7 Compliance Frameworks Supported	4
1.8 Integrations	4
1.9 Evidence Bundles	4
1.10 Deployment Modes	5
1.11 Why AlDeci is Different	5
1.12 Get Started	5

1 AlDeci Product One-Pager

Formerly FixOps

1.1 Automate Trust. Prove Security.

AlDeci is a comprehensive DevSecOps platform that transforms scanner noise and SBOM sprawl into risk-based actions and cryptographically signed evidence bundles.

1.2 The Problem

Organizations face three critical challenges in modern DevSecOps:

- **Scanner Noise:** Multiple security tools generate overlapping findings with high false-positive rates, overwhelming security teams

- **SBOM Sprawl:** Software Bill of Materials from different tools use incompatible formats (CycloneDX, SPDX, GitHub Dependency Snapshot), making correlation impossible
 - **Audit Burden:** Manual evidence collection for compliance frameworks (SOC 2, ISO 27001, APRA CPS 234, Essential Eight) consumes 40-60% of security team time
-

1.3 The AlDeci Solution

AlDeci unifies security intelligence into a single automated workflow:

Unified Ingestion → Accepts SBOMs (CycloneDX, SPDX), SARIF scans (SAST/DAST/SCA), CNAPP findings, VEX documents, and business context through REST API or CLI

Intelligent Normalization → Converts heterogeneous formats into canonical models for consistent analysis

Context-Aware Correlation → Links design artifacts ↔ SBOM components ↔ security findings ↔ CVE data ↔ existing controls for full traceability

Risk-Based Prioritization → Combines EPSS (exploit probability), CISA KEV (known exploited vulnerabilities), version lag, exposure flags, and data sensitivity into composite risk scores (0-100)

Automated Evidence Generation → Produces cryptographically signed, audit-ready bundles with SLSA v1 provenance attestations for compliance frameworks

1.4 How AlDeci Works: 6-Step Decision Flow

AlDeci processes vulnerabilities through a systematic 6-step flow that combines threat intelligence, probabilistic modeling, architecture-aware threat assessment, compliance mapping, and explainable AI:

1.4.1 Step 1: Enrichment

Inputs: EPSS, KEV, CVSS, CWE, ExploitDB (coming soon)

Output: Enriched CVE metadata with exploit probability signals and weakness patterns

1.4.2 Step 2: Forecasting

Inputs: Markov chain (5-state model), Bayesian analytics

Output: Risk projection with posterior probability $P(\text{exploit} \mid \text{signals})$ and vulnerability trend forecast

1.4.3 Step 3: Threat Modeling

Inputs: Architecture baseline, threat tree (Beta), MITRE ATT&CK techniques

Output: Exploitability assessment per component based on applicable techniques, exposure, and controls

1.4.4 Step 4: Compliance Mapping

Inputs: Org-specific controls, SOC2, ISO 27001, APRA CPS 234, Essential Eight

Output: Control coverage report with policy violations and compliance gaps

1.4.5 Step 5: LLM Explanation

Inputs: Multi-LLM consensus (GPT-5, Claude-3, Gemini-2), RAG with vector DB, hallucination guard

Output: Natural language explanation with confidence score and mathematical backing

1.4.6 Step 6: Final Verdict

Inputs: All prior steps + policy overlay

Output: Tri-state classification with gate mapping

Verdict Types: - **Exploitable** → CVE enables baseline-critical technique + component exposed + controls insufficient → Gate: BLOCK or FIX (policy-dependent) - **Not Exploitable** → CVE not in threat baseline OR controls sufficient OR component not exposed → Gate: ALLOW (with evidence bundle) - **Needs Review** → Insufficient data, low LLM confidence, or missing threat baseline → Gate: FIX or require human approval

1.5 MITRE ATT&CK: Dual Role

Design-Time Baseline (Beta): Teams provide system architecture to define applicable techniques per component. This baseline feeds Step 3 (Threat Modeling) and Step 4 (Compliance Mapping) policies.

Runtime Evidence (Available): LLM identifies MITRE techniques during Step 5 reasoning. Technique mappings are included in evidence bundles for threat context and audit transparency.

1.6 Proven Outcomes

Organizations using AIDeci achieve measurable security and efficiency gains:

- **–60% False-Positive Churn** - Context-aware correlation eliminates duplicate and irrelevant findings

- **–46% MTTR for Critical Vulnerabilities** - Risk-based prioritization focuses teams on exploitable issues
 - **–80% Audit Preparation Time** - Automated evidence bundles eliminate manual artifact collection
-

1.7 Compliance Frameworks Supported

AlDeci generates audit-ready evidence for:

- **SOC 2 Type II** - Security monitoring, change management, incident response evidence
 - **ISO 27001** - Information security management system controls and audit trails
 - **APRA CPS 234** - Information security capability for Australian financial institutions
 - **Essential Eight** - Australian Cyber Security Centre mitigation strategies
-

1.8 Integrations

CI/CD Platforms: GitHub Actions • GitLab CI • Azure DevOps • Jenkins • CircleCI

Security Scanners: Snyk • Wiz • Tenable • SonarQube • Nexus Lifecycle • Semgrep • Trivy

Ticketing & Collaboration: Jira • Azure Boards • Confluence • Slack • Microsoft Teams

Cloud Providers: AWS • Azure • GCP • Kubernetes

1.9 Evidence Bundles

Every AlDeci decision produces a cryptographically signed evidence bundle containing:

- Normalized SBOM with component inventory and licenses
- Risk report with EPSS/KEV analysis and composite scores
- SARIF findings with severity mapping and remediation guidance
- SLSA v1 provenance attestation with build metadata
- Policy evaluation results (pass/warn/fail verdicts)
- Signed MANIFEST.yaml with SHA-256 fingerprints

Signing Options: RSA-SHA256 or Cosign with optional Fernet encryption at rest

Retention: 90 days (Demo Mode) or 7 years (Enterprise Mode)

1.10 Deployment Modes

Demo Mode - In-memory vector store, mock LLM, simplified auth, 90-day retention

Enterprise Mode - Persistent ChromaDB, real LLM APIs, JWT auth, 7-year retention, OPA client

1.11 Why AlDeci is Different

Push-Based Architecture - Teams push artifacts from CI/CD pipelines—no scanner-specific connectors required. Works with any tool that outputs SBOM or SARIF.

Evidence + Prioritization in One Flow - Single workflow produces both risk-based prioritization and audit-ready evidence. No separate compliance tools needed.

On-Premises Friendly - Transparent pipeline with explainable outputs. Deploy in your VPC or on-premises. No black-box SaaS required.

Cryptographic Trust - Every decision is signed and verifiable. Immutable audit trails with SLSA v1 provenance.

1.12 Get Started

Request Access → contact@devops.ai

Book a Demo → <https://devops.ai/contact>

Documentation → <https://deepwiki.com/DevOpsMadDog/Fixops>

DevOps.ai | Sydney, Australia | <https://devops.ai>

© 2025 DevOps.ai. All rights reserved.